

Copilot Chat, HIPAA, and Web Search

What actually crosses the tenant boundary, what is covered by your BAA, and how to govern it. A plain-language guide for IT and security teams in regulated industries.

Author: Michael Goad • Copilot Solution Engineer • Sources: Microsoft Learn

There is a lot of confusion about what Microsoft 365 Copilot Chat does and does not do with your data, especially around web search and HIPAA. This guide breaks it down two ways: a short version that answers the core concerns directly, then a longer walkthrough of each piece, what it means, and how it impacts a regulated environment.

THE SHORT VERSION

Copilot Chat (the enterprise, no-cost experience) keeps your prompts and responses inside your Microsoft 365 service boundary, covered by Enterprise Data Protection and your BAA. The one component that reaches outside that boundary is **web search** (the "From the web" results powered by Bing). Web search is **not** covered by the BAA, by design, for every customer. Even so, what actually leaves the tenant is a short, de-identified keyword query over an encrypted connection, and you have several layers of control and visibility over it.

1 What stays inside your tenant (covered by your BAA)

When a user types a prompt into Copilot Chat and Copilot answers using your data or its own reasoning, that whole interaction stays inside the Microsoft 365 service boundary:

- Prompts and responses are protected by **Enterprise Data Protection (EDP)**, the same contractual terms (Data Protection Addendum plus Product Terms) that already cover email in Exchange and files in SharePoint.
- It is **encrypted at rest and in transit**, with tenant isolation between customers.
- It **inherits existing governance**: identity model and access controls, sensitivity labels, retention policies, and audit. Copilot only ever surfaces data the individual user already has permission to see.
- Prompts and responses are **never used to train foundation models**.
- This portion is covered by the BAA.

So for the core experience, the answer to "does it stay in our tenant and inherit our DLP, audit, and access controls" is yes, depending on which controls have been implemented and the licensing level.

2 What happens when web search is involved (the part outside the BAA)

This is the piece that causes most of the confusion, and the instinct that web search behaves differently is correct.

When web search is enabled and Copilot decides the web would improve an answer, it does **not** send the prompt to the internet. Instead it generates a short search query (literally a few keywords, very similar to what you would type into Google) and sends only that to the **Bing search service**. The Bing search service runs separately from Microsoft 365, under the Microsoft Services Agreement, with Microsoft acting as an independent data controller. Because it sits outside the M365 boundary, the BAA does not extend to it. That is true for every customer, and it is stated plainly in Microsoft's documentation.

WHAT THAT MEANS IN PRACTICE

The protections layered on top of web search matter:

- **Only keywords leave, never the full picture.** The following are explicitly never sent to Bing: your entire prompt (unless it is something trivial like "local weather"), entire emails, documents, or uploaded files, entire web pages or PDFs being summarized, and any identifying information from Entra ID (username, domain, or tenant ID).
- **It is de-identified.** User and tenant identifiers are stripped before the query is sent, so there is no "this came from this organization" attached to it.
- **It is encrypted and protected in transit.** The query travels over a secure, encrypted connection specifically so it cannot be intercepted or altered in flight.
- **It is logged in the Bing search service for a limited duration** and is only accessible by authorized Microsoft employees.
- **It is not monetized or used to train.** These queries are treated as customer confidential. They are not shared with advertisers, not used to build advertising profiles, not used to improve Bing, and not used to train generative AI foundation models.

So while web search is technically outside the scope of the BAA, the data that crosses the boundary is minimized, anonymized, and encrypted.

3 Yes, it is fully auditable (the part most people miss)

Everything in Copilot Chat carries an audit trail in Microsoft and can be retrieved with Purview, and this works on both **E3** and **E5**:

- The user's prompt, Copilot's response, and the **exact web search keywords** Copilot sent to Bing are all logged and reviewable. You can run search, audit, and eDiscovery against them using the same Purview tools your compliance team already uses.
- Users themselves see the exact web queries that were run, shown as citations in the response, so there is transparency at the point of use too.

The difference between E3 and E5 here is mostly experience, not coverage: **E5 (with DSPM for AI)** gives you a single pane where you can see the original prompt, the response, the web keywords, and the supporting resources side by side as one storyline. E3 has the underlying audit data; E5 makes the investigation faster.

4 Where E5 gets you proactive PHI control

This is the strongest answer to "how do we keep sensitive data from going out." With **E5 and DLP for Microsoft 365 Copilot**, you move from detective (auditing after the fact) to **preventive**:

- DLP can detect **sensitive information types** (Social Security numbers, credit card numbers, MRNs, and other PHI patterns) using deep content analysis, not a simple text scan.
- You can configure policy so that content carrying certain sensitivity labels is excluded from Copilot processing, and use DSPM for AI plus collection policies to flag or restrict sensitive material in the AI interaction itself.
- Practically, this lets you put guardrails in place so the most sensitive data is governed before it is ever part of a prompt or a generated query.

5 Direct answers to the common questions

Does data stay in our tenant and inherit our DLP, audit, and access controls?

For prompts and responses, yes, fully. For web search, a minimized, de-identified keyword query leaves the tenant by design.

Are Bing / web searches covered under our BAA?

No. Web search is outside the BAA for all customers. It is protected by Microsoft commitments (encryption, de-identification, no training, no ads).

What does "web search" actually cover?

It covers the "From the web" grounding results. It is triggered only when Copilot judges the web will improve an answer, and only a few generated keywords are sent and stored, not your prompt or response.

Retention, PHI monitoring, compliance posture?

Prompts, responses, and web keywords follow your retention policies and are auditable in Purview on E3 / E5. PHI monitoring is detective on E3 and can be made preventive on E5 via DLP and DSPM for AI.

6 Common adoption patterns in regulated environments

To put it in context, organizations in healthcare and other regulated industries tend to land in a few common places once they understand the keyword-only, de-identified, encrypted reality of web search:

- **Enable Copilot Chat and keep web search on.** The actual data crossing the boundary is minimal and anonymized, and the productivity value is high. Purview auditing provides assurance.
- **Start conservative, then expand.** Disable web search via the admin controls (or the user-level Web content toggle) during an initial rollout, then turn it on once security and compliance teams have reviewed the audit trail and DLP posture.
- **Lead with E5 controls for the most risk-averse.** Deploy E5 DLP for Copilot and DSPM for AI so PHI controls are preventive before broad adoption.

7 Recommended best practices for rollout

- **Turn on Purview Audit** (it is on by default for newer tenants) and confirm Copilot interactions, including web search keywords, are being captured. This gives leadership evidence, not assurances.
- **Decide your web search posture deliberately.** Leave it on (recommended for value, given the protections), or scope it down with admin controls during a pilot. Either way, make it an explicit decision rather than a default.
- **On E5, deploy DLP for Microsoft 365 Copilot** targeting your PHI sensitive information types and sensitivity labels, so the most sensitive content is governed proactively.
- **Train users on the boundary, simply:** Copilot Chat for internal reasoning over your data is fully covered; web search returns public information and should not be treated as a place to paste PHI. Pairing the human guardrail with the technical one is what mature organizations do.
- **Phase the rollout:** pilot group, review the audit data together, then expand. It gives the compliance team a clean before-and-after story.

BOTTOM LINE

The core Copilot Chat experience stays inside your protected boundary and is covered by your BAA. Web search is the one piece that reaches out, and it reaches out with a few anonymized keywords over an encrypted connection, fully logged and auditable. This is a very governable set of trade-offs, not a reason to avoid the tool.

Microsoft documentation for security and compliance teams

Microsoft 365 Copilot Chat: privacy and protections

The architecture, what stays in-boundary, and the green shield.

<https://learn.microsoft.com/en-us/copilot/privacy-and-protections>

Enterprise Data Protection (EDP)

The contractual terms covering prompts and responses, plus the explicit BAA / HIPAA note on web search.

<https://learn.microsoft.com/en-us/copilot/microsoft-365/enterprise-data-protection>

Data, privacy, and security for web search

What is and is not sent to Bing, keyword examples, query logging and audit.

<https://learn.microsoft.com/en-us/copilot/microsoft-365/manage-public-web-access>

Data, privacy, and security for Microsoft 365 Copilot

HIPAA, permissions, and training commitments overview.

<https://learn.microsoft.com/en-us/copilot/microsoft-365/microsoft-365-copilot-privacy>

Purview audit log activities

Where Copilot prompts, responses, and web queries are logged.

<https://learn.microsoft.com/en-us/purview/audit-log-activities>

Retention for Copilot and AI apps

How prompts and responses are retained and deleted.

<https://learn.microsoft.com/en-us/purview/retention-policies-copilot>

Learn about Data Loss Prevention

Sensitive info types such as SSN, credit card, and health records.

<https://learn.microsoft.com/en-us/purview/dlp-learn-about-dlp>

Data Security Posture Management (DSPM) for AI

Proactive monitoring, the full prompt-to-web-query storyline, and data risk assessments.

<https://learn.microsoft.com/en-us/purview/dspm-for-ai>

About this resource. This is a personal educational summary created by Michael Goad to help IT and security teams reason about Copilot Chat, HIPAA, and web search. It is not official Microsoft guidance and does not constitute legal or compliance advice. Product behavior, licensing, and terms change over time: always verify against the linked Microsoft Learn documentation and validate any compliance decision against your own environment, licensing, BAA, and legal counsel. Specific controls vary by Microsoft subscription plan.